

TECHNICAL REPORT

OpenCTI 7系 Enterprise Edition でできること

— AI機能を軸とした包括的レポート —

作成日 2026年8月27日

対象 OpenCTI 7.260710.0 / XTM One 1.260711.0

公式ドキュメント・実装コード・実機検証にもとづく

全5図・実測データ収録

目次

0. このレポートについて

目的 / 調査方法 / 検証環境

1. 前提知識

CTIとは / OpenCTIとは / STIXとは / CE と EE の違い

2. Enterprise Edition の全体像 [図1]

EE機能の一覧（14項目） / 実装から確認した EE 判定箇所

3. AI機能 — 本レポートの主題 [図2・図3・図5]

3.1 最重要の前提: AIの経路は2つある

3.2 Ask AI — 文章作成の支援

3.3 AI Insights — エンティティの自動分析

3.4 自然言語クエリ（NLQ）

3.5 文書からのSTIX抽出 — 実測による比較

3.6 レポート生成 / 3.7 XTM One のエージェント

3.8 MCP サーバーとしての公開

4. AI以外の Enterprise Edition 機能

プレイブック / PIR / ドラフト / 全文索引 / 監査ログ / セグリゲーション / Fintel / 配信 / SSO

5. 何に使えるか — ユースケース別 [図4]

取り込み効率化 / 脅威の選別 / 報告作成 / 利用者拡大 / 組織統制

6. ライセンスと導入

7. 注意点と限界

8. まとめ

付録A 用語集 / 付録B 検証環境 / 付録C 参考資料

— AI機能を軸とした包括的レポート —

0. このレポートについて

0.1 目的

OpenCTI 7系の Enterprise Edition（以下 EE）で何ができるのかを、AI機能を中心に体系的に整理したものである。「どんな機能があるか」「それは何のために使うのか」の2点を軸に構成した。

0.2 調査方法

本レポートは以下の3つを突き合わせて作成した。

情報源	内容
公式ドキュメント	docs.opencti.io および filigran.io の記載
実装コード	稼働中インスタンスのバックエンドバンドルから、EE判定の実装箇所を抽出
実機検証	ローカルに構築した環境での実際の動作確認

事実の確度について: 公式ドキュメントの一部（AI チャット、AI Insights）は執筆時点で "Under construction" であり、記載が存在しない。そのため本レポートでは、確認できた事実と確認できなかった事項を明示的に区別する。推測は「推測である」と明記し、断定は避ける。

0.3 検証環境

Apple Silicon 搭載の 16GB メモリの Mac 上に Docker Compose で構築した。コンテナ構成は以下のとおりである。

- コア6コンテナ: OpenCTI 本体、Elasticsearch、MinIO、RabbitMQ、Redis、ワーカー
- AI拡張5コンテナ: XTM One 本体、XTM One ワーカー、PostgreSQL (pgvector)、XTM Composer、鍵生成
- 推論モデル: Ollama Cloud 上の `gpt-oss:120b-cloud`

知識ベースには MITRE ATT&CK の全データと公開レポート24件が投入済みである（Entity 6,427件、関係 26,439件）。

1. 前提知識

本編に入る前に、最低限の用語を整理する。

1.1 CTI（サイバー脅威インテリジェンス）とは

CTI は Cyber Threat Intelligence の略である。「誰が、どんな手口で、誰を狙っているか」という攻撃者に関する知識を収集・整理・活用する営みを指す。

単なるウイルス対策との違いは、**攻撃者を主語にする**点にある。「このファイルは危険か」ではなく「この攻撃グループは次にどこを狙うか」「自社の検知ルールはその手口を捉えられるか」を考えるための情報である。防御側にとっては、SOC のアラートトリアージ、脅威ハンティングの仮説立案、検知ルールの設計といった判断の土台になる。

1.2 OpenCTI とは

OpenCTI は、フランスの Filigran 社が開発するオープンソースの CTI プラットフォームである。役割は「攻撃者に関する知識のデータベース兼分析環境」と言える。

主な機能は次の3つに集約される。

1. **集める** — 外部の脅威情報フィード、レポートPDF、他組織からの共有データを取り込む
2. **つなぐ** — 「攻撃グループAがマルウェアBを使う」「マルウェアBが企業Cを狙う」といった関係をグラフとして構築する
3. **使う** — 検索、可視化、他システムへの連携により、防御の意思決定に役立てる

1.3 STIX とは

STIX（Structured Threat Information Expression、スティックスと読む）は、脅威情報を記述するための国際標準フォーマットである。

たとえば「APT41 という攻撃グループが DUSTPAN というマルウェアを使う」という事実を、機械が読める JSON 形式で表現する。組織間で情報を共有する際の共通言語にあたる。OpenCTI の内部データ構造はこの STIX 2.1 に準拠している。

本レポートで頻出する STIX の用語を挙げる。

用語	意味
Entity	攻撃グループ、マルウェア、脆弱性などの「モノ」
Relationship	Entity 同士のつながり。「使う」「狙う」など
Observable	IPアドレス、ドメイン名、ファイルハッシュなど観測された値そのもの
Indicator	「この値を見たら攻撃の兆候」と判断するための検知ルール
Bundle	複数の STIX オブジェクトをまとめて受け渡すための入れ物。ファイルやAPIでやりとりする単位

1.4 Community Edition と Enterprise Edition

OpenCTI には2つのエディションが存在する。

Community Edition (CE) は無償のオープンソース版である。データの収集、蓄積、関係グラフの構築、検索、可視化といった**CTIプラットフォームとしての基本機能はすべて含まれる**。CEだけでも実用的なCTI基盤として成立する。

Enterprise Edition (EE) は、CEに以下の性格の機能を追加する。

- **AI機能** — 本レポートの主題
- **自動化** — 人手を介さない処理フロー
- **組織運用** — 監査、アクセス制御、認証統合
- **成果物作成** — ブランド付きレポート出力、配信

つまり EE は「個人や小規模チームが使う道具」を「組織で回すシステム」に引き上げるための拡張である、と整理できる。

2. Enterprise Edition の全体像

Enterprise Edition が追加する14機能

AI 機能	自動化	組織運用・統制	成果物の作成・配信
AI Insights 要約・予測の自動生成 Ask AI（文章支援） 要約・整形・トーン変更 自然言語クエリ NLQ 普通の文で検索 自然言語処理 NLP 文書から関係を抽出 + XTM One 導入で エージェント型AI MCP サーバー公開	プレイブック ノーコードの自動処理 エンリッチ・振り分け PIR（優先情報要求） 重要な脅威を自動選別 スコアで優先度付け	Activity Monitoring 監査ログ 組織セグリゲーション 組織単位の見せ分け Authorized Members 個別データの権限制御 ドラフト権限制御 本番直接編集を禁止 SSO 認証基盤との統合 全文ファイル索引 PDF等の中身を検索	Fintel テンプレート ブランド付きPDF出力 配信リスト 関係者へメール配信 メールテンプレート 通知文面の定型化
Community Edition（無償・オープンソース） データ収集 / 関係グラフ / 検索 / 可視化 / ダッシュボード / ケース管理 / コネクタ連携 — CTIプラットフォームとしての基本機能はすべてここに含まれる			

図1 Enterprise Edition の機能マップ。CE の基本機能の上に、性格の異なる4分類の機能が積み上がる。

2.1 EE機能の一覧

公式ドキュメントが列挙する EE 機能は14項目である。これを実装コード側の EE 判定箇所（58箇所）と突き合わせ、性格別に4分類したものが以下である。

分類	機能	一言でいうと
AI	AI Insights	Entity の要約・予測をAIが生成する
AI	Ask AI（文章支援）	文章の要約・整形・トーン変更をAIが行う
AI	自然言語クエリ（NLQ）	日本語などの普通の文で検索できる
AI	自然言語処理（NLP）	文章から Entity と関係を自動抽出する
自動化	プレイブック	取り込んだデータを自動で加工・振り分けする
自動化	PIR（優先情報要求）	自組織にとって重要な脅威を自動で選り分ける
運用	Activity Monitoring	「誰が何をしたか」の監査ログ
運用	組織セグリゲーション	組織単位でデータを見せ分ける
運用	Authorized Members	個別データへのアクセスを細かく制御する
運用	ドラフトモード権限制御	本番データを直接編集させない運用を強制する
運用	SSO	既存の認証基盤と統合する
検索	全文ファイル索引	PDFなどの中身まで検索対象にする
成果物	Fintel テンプレート	自社ブランドのPDFレポートを出力する
成果物	配信リスト	完成したレポートをメールで配信する
成果物	メールテンプレート	通知メールの文面を定型化する

2.2 実装から確認した EE 判定箇所

実際のバックエンドコードで EE ライセンスを検査している関数を抽出したところ、以下の機能群が該当した。ドキュメントの記載と整合している。

AI系 : aiSummary, aiForecast, aiActivity, aiHistory
summarize, explain, changeTone, fixSpelling,
makeShorter, makeLonger
convertFilesToStix, summarizeFiles,
generateContainerReport

自動化系 : createPlaybook, playbookEdit, playbookAddNode,
playbookAddLink, playbookDelete ほか

PIR系 : pirAdd, deletePir, findPirPaginated,
findPirContainers, pirEditAuthorizedMembers

成果物系 : addFintelDesign, uploadFintelDesignFile,
addDisseminationList, sendToDisseminationList,
sendEmailToUser, deleteEmailTemplate

その他 : draftWorkspaceEditContext, setWorkflowDefinition

なお **Security Coverage**（防御力バレッジ評価）については、ドキュメントに EE 必須の明記がなく、コード側の EE 判定にも該当が見られなかった。CE でも利用できる可能性が高いが、断定は避ける。

3. AI機能 — 本レポートの主題

3.1 最重要の前提: AIの経路は2つある

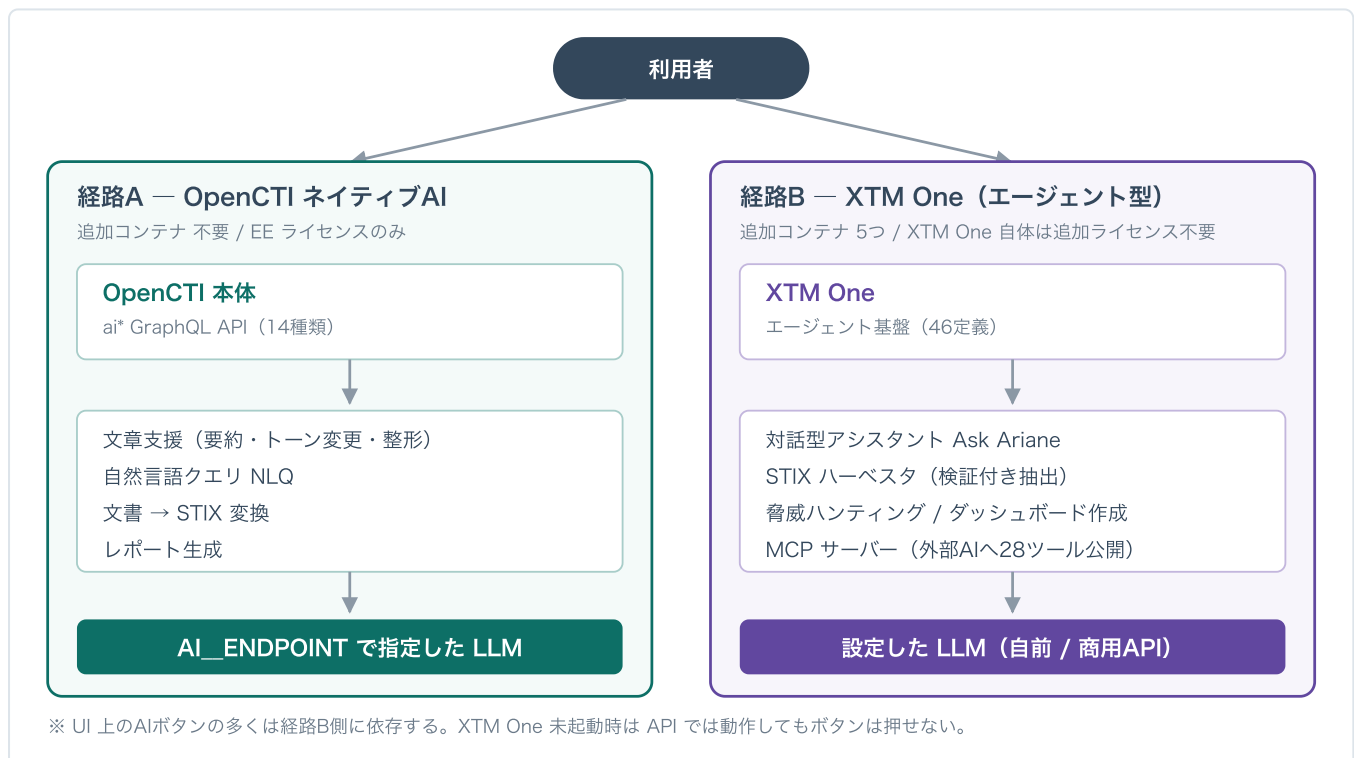


図2 AI機能の2系統。名前が似ているが実行経路は完全に独立している。

OpenCTI 7系の AI 機能を理解する上で、**最初に押さえるべき最も重要な事実**がこれである。名前が似ているため混同しやすいが、AIの実行経路は完全に独立した2系統が存在する。

経路A — OpenCTI ネイティブAI

OpenCTI 本体が自前で持つAI機能である。設定した LLM（大規模言語モデル）のエンドポイントを直接呼び出す。

- 設定方法: OpenCTI の環境変数 `AI__ENABLED`、`AI__TYPE`、`AI__ENDPOINT`、`AI__MODEL` など
- 対応プロバイダ: 実装コード上は `mistralai`、`openai`、`azureopenai` の3種類
- 追加コンテナ: **不要**（OpenCTI 本体だけで動く）
- 提供される機能: 文章支援、NLQ、文書→STIX変換、レポート生成など14種類のAPI

補足として、`openai` タイプは「OpenAI互換のエンドポイント」を指定できるため、**ローカルの Ollama や自社ホストの推論サーバーを向けることが可能**である。検証環境ではこの方式で Ollama Cloud のモデルを利用した。

経路B — XTM One（エージェント型AI）

XTM One は Filigran 社が2026年6月に発表した、**エージェント型AIの基盤**である。OpenCTI とは別のコンテナ群として動作する。

「エージェント型」とは、AIが単発の質問に答えるだけでなく、**目標を与えると自分で手順を考え、道具を使い、結果を検証しながら作業を進める**方式を指す。SOC の業務でいえば、「このログを要約して」と指示するのではなく、「このアラートを調査し、関連する脅威情報を添えて報告して」と任せるイメージである。

- 追加コンテナ: 5つ（XTM One本体、ワーカー、PostgreSQL、Composer、鍵生成）
- ライセンス: XTM One 自体は追加ライセンス不要（接続先の OpenCTI の EE ライセンスで判定される）
- 提供される機能: 対話型アシスタント「Ask Ariane」、専用エージェント群、MCP サーバー

XTM One はオープンソースであり、実装は GitHub 上で公開されている（`XTM-One-Platform/xtm-one`）。

2つの経路の使い分け

	経路A（ネイティブ）	経路B（XTM One）
起動コスト	追加コンテナ不要	5コンテナ追加
UI からの操作	一部のボタンのみ	チャット、エージェント選択
処理の性格	単発のプロンプト実行	複数手順の自律実行
出力の検証	なし	スキーマ強制・バリデータあり
外部連携	なし	MCP サーバーとして公開可能

重要な注意点: UI 上の AI ボタンの多くは経路B側に寄せられている。XTM One を起動していない状態では、API 経由では経路Aの機能が動作するにもかかわらず、画面上のボタンは「XTM One を設定してください」と表示されて押せない。これは実機検証で確認した事実である。

3.2 Ask AI — 文章作成の支援

Entity の説明欄やレポート本文など、テキストを入力する場所で利用できる機能である。EE 必須と公式ドキュメントに明記されている。

できること

機能	内容
スペル・文法の修正	誤字や文法の誤りを訂正する
長さの調整	文章を短くする／詳しく膨らませる
トーン変更	読み手に合わせて書き分ける
箇条書き要約	長文を要点のリストに変換する
解説	専門的な記述を平易に説明する

トーン変更は3段階が用意されている。この設計自体が CTI 実務の構造をよく表している。

- **Strategic（戦略）** — CISO・経営層向け。技術的詳細を落とし、事業影響とリスクを語る
- **Tactical（戦術）** — SOC マネージャーやインシデント対応リーダー向け。対応方針を判断できる粒度
- **Operational（運用）** — SOC アナリストや検知エンジニア向け。手口とIOCの詳細まで含む

何に使えるか

インシデントを1件分析したあと、同じ内容を CISO への報告書と、当番アナリストへの引き継ぎメモに書き分ける作業は、防御側の時間を最も食う定型業務のひとつである。これを自動化できる点に実務的価値がある。

3.3 AI Insights — Entity の自動分析

個別の Entity（攻撃グループやマルウェアなど）を開いたときに、AIがその対象について自動で分析を提示する機能である。

実装コードから確認できた種類は4つである。

種類	内容
aiSummary	対象に関する情報の要約
aiForecast	今後の動向予測
aiActivity	活動状況の分析
aiHistory	変更履歴の要約

公式ドキュメントの該当ページは執筆時点で "Under construction" であり、各機能の詳細な説明は公開されていない。上記は実装コードからの確認結果である。

設定項目として `insights_refresh_timeout`（既定60分）が存在し、生成結果がキャッシュされる仕組みであることが読み取れる。

3.4 自然言語クエリ（NLQ） — 普通の文で検索する

何をするものか

OpenCTI の検索は本来、フィルタ条件を組み立てて指定する必要がある。「Entity 種別が Malware で、かつ APT41 との間に uses 関係があるもの」といった具合である。この構文を覚えるのは負担が大きい。

NLQ は、普通の文章で書いた質問をフィルタ条件に翻訳する機能である。

実機で確認した動作

検証環境で日本語の質問を投げたところ、以下の結果を得た。

```
質問：「APT41 が使うマルウェア」
生成されたフィルタ：
  relationship_type = "uses"
  id = 9a126130-... (APT41 の Entity ID)
  entity_type = "Malware"
所要時間：5〜23秒
```

質問：「台湾を標的にした攻撃グループ」

生成されたフィルタ：

```
relationship_type = "targets"
```

```
id = e80706f6-... (Taiwan の Entity ID)
```

```
entity_type = ["Threat-Actor-Group", "Threat-Actor-Individual", "Intrusion-Set"]
```

所要時間： 4秒

注目すべきは2点である。第一に、**日本語がそのまま通る**。第二に、単なるキーワード検索ではなく「使う」を **uses** 関係に、「標的にした」を **targets** 関係に翻訳し、さらに「台湾」「APT41」を**データベース内の実際の Entity IDに解決している**。ID の正しさは個別に照合して確認した。

公式が明示する制約

ドキュメントには以下の制約が記載されている。

- 関係そのものは検索できない (Entity のみ)
- 日付による絞り込みには対応していない
- 関連 Entity の属性による絞り込みには対応していない
- 多階層の AND / OR 組み合わせには対応していない

何に使えるか

CTI プラットフォームの導入で最大の障壁は、CTI 専任アナリスト以外が使えないことである。NLQ は、フィルタ構文を知らない人にもデータへの入口を開く。たとえば夜間当番の SOC アナリストが、アラートに出てきたドメイン名について「このドメインを使う攻撃グループ」と尋ねるだけで、社内の蓄積を引ける。

3.5 文書からのSTIX抽出 — AIの効果が最も明確な領域

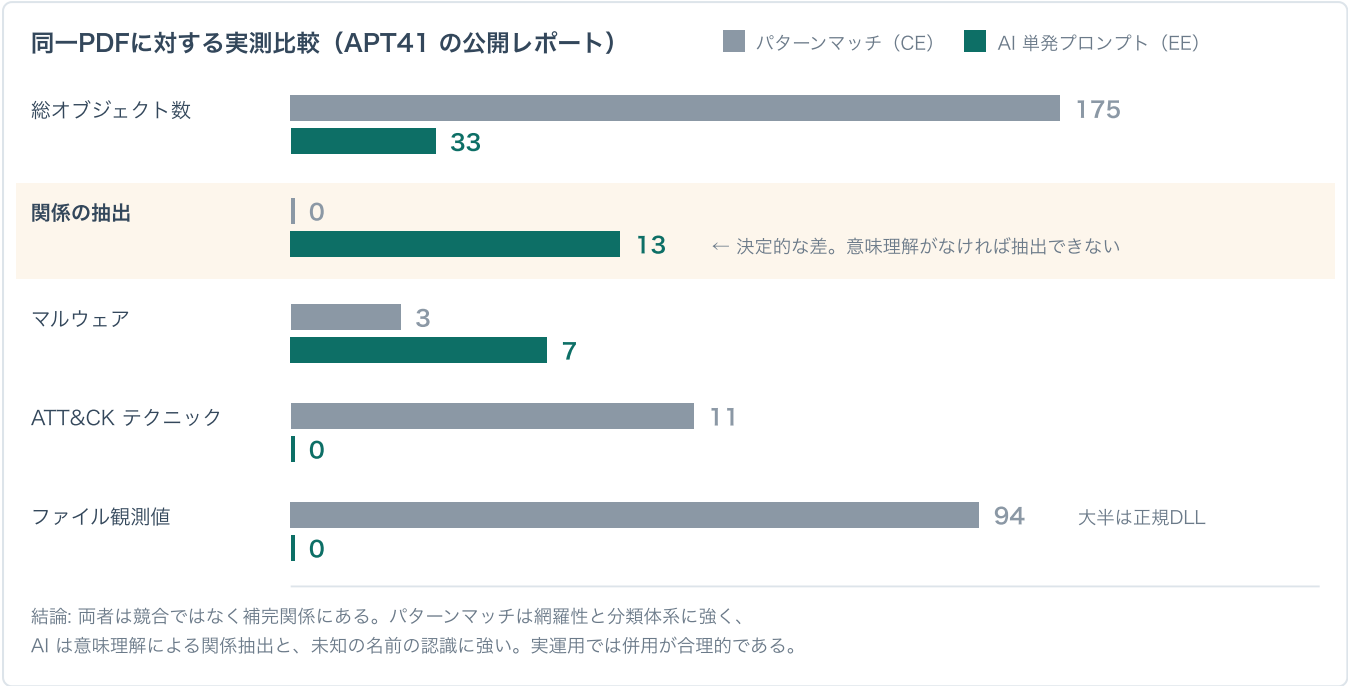


図3 文書からのSTIX抽出の実測比較。数の多さと質は一致しない。

何をするものか

脅威レポートのPDFを読み込ませ、そこに書かれている攻撃グループ、マルウェア、IPアドレスなどを抽出して、構造化データ（STIX）に変換する機能である。

CTI 実務において、この「PDFを読んで手作業でデータ化する」工程は最大のボトルネックである。1本のレポートに数十の Entity と関係が含まれ、それを人手で入力すると数時間を要する。

3つの方式

OpenCTI では同じ目的に対して3通りの実装が存在する。ここが混同されやすい。

方式	実体	AI	ライセンス
ImportDocument コネクタ	正規表現によるパターンマッチと既存 Entity 照合	限定的	CE
aiConvertFilesToStix	LLMへの単発プロンプト	あり	EE
cti-stix-harvester	XTM One のエージェント（スキーマ強制+検証付き）	あり	EE + XTM One

実測による比較

同一のPDF（APT41 に関する公開レポート）に対し、前者2方式を実行して結果を比較した。

項目	パターンマッチ	AI（単発プロンプト）
抽出オブジェクト数	175	33
関係の抽出	0	13
マルウェア	3	7
ATT&CK テクニック	11	0
ファイル観測値	94	0
Indicator	0	6
所要時間	約40秒	115秒

この結果の読み方

数だけ見るとパターンマッチが優勢に見えるが、中身の質が異なる。

パターンマッチが抽出した94件のファイル観測値は、その大半が正規のWindows DLLファイル名であった。また電話番号として抽出された8件は、すべてIPアドレスや日付の誤検出であった。**機械的に拾えるものをすべて拾うため、ノイズも多い。**

一方 AI は、**関係を13件抽出した**。パターンマッチは0件である。ここが決定的な差である。「APT41 が DUSTPAN を使う」という関係は、文章の意味を理解しなければ抽出できない。CTI の価値の中核は関係グラフにあるため、この差は大きい。

また AI は、事前に名前を知らないマルウェア（ANTSWORD、PINEGROVE など5件）を文脈から認識した。パターンマッチは既知のリストと照合するため、新種を拾えない。

結論として、両者は競合ではなく補完関係にある。 パターンマッチは網羅性と分類体系（地域、業種、ATT&CKテクニック）に強く、AIは意味理解による関係抽出と未知の名前の認識に強い。実運用では両方を走らせ、結果を統合するのが合理的である。

3.6 レポート生成

Container（レポート、ケースなど）に紐づく知識グラフをもとに、AIが報告文を生成する機能である。実装上は `generateContainerReport`、`aiThreatGenerateReport`、`aiVictimGenerateReport` の3種類が存在し、それぞれ Container 単位、脅威アクター単位、被害者視点での生成に対応する。

何に使えるか

すでに構造化された知識から文章を起こす作業は、逆方向（文章から知識を抽出する作業）と同じく定型的である。SOC の週次脅威サマリー、インシデント対応報告書の初稿、シフト交代時の引き継ぎ資料の作成などが想定用途である。

3.7 XTM One のエージェント

XTM One を導入すると、事前構築済みのAIエージェント群が利用可能になる。実装から確認したエージェント定義は46件である。主なものを挙げる。

エージェント	役割
OpenCTI Assistant	OpenCTI に関する汎用アシスタント
CTI STIX Harvester	文書からSTIXを抽出（スキーマ強制+バリデータ付き）
CTI STIX Transformer	STIX Bundle の変換・正規化
OpenCTI Entity Insights	Entity の要約・活動分析・予測
OpenCTI Threat Hunt Creator	脅威ハンティングのクエリ作成
OpenCTI Dashboard Creator	ダッシュボードの自動作成
Detection Rule Converter	検知ルールの形式変換
CTEM Assistant	継続的脅威エクスポージャ管理の支援

エージェント定義は「ペルソナ（役割設定）」「出力スキーマ」「使える道具」「最大反復回数」などから構成される。たとえば `cti-stix-harvester` は温度 0.0（出力のランダム性を排除）、最大 5 反復、`stix_bundle_validator` という検証ツールを装備し、出力が STIX として妥当であることを機械的に確認する設計である。

注意すべき点

エージェントのうち2つ（`cti-stix-harvester-filigran-ai`、`cti-ttp-harvester-filigran-ai`）は、**既定で Filigran 社のクラウドサービスに文書を送信する**。これらは Filigran が独自にファインチューニングしたモデル（STIX側は "Orion" と呼称）を利用するため、ローカルでは動作しない設計である。

環境変数 `FILIGRAN_AI_BASE_URL_STIX` および `FILIGRAN_AI_BASE_URL_TTP` で送信先を変更できる。機密文書を扱う場合は必ず確認すべき箇所である。なお同名のローカル版エージェント `cti-stix-harvester` は、設定した自前のLLMで動作する。

3.8 MCP サーバーとしての公開

MCP による外部AIアシスタント連携

MCP = AIが外部のツールやデータに接続するための標準規格



公開される28ツールの内訳

検索・読み取り 11 / 作成 6 / 更新 2 / 削除 2 / ラベル・マーキング 4 / Container 操作 2 / 昇格 1
ユーザー管理・ロール・プレイブック・コネクタ・設定などの管理系は、許可リストにより除外されている

※ 削除系ツールは下書きを経由せず即座に本番反映される。接続時は権限を絞った専用ユーザーを用意すべきである。

図5 MCP連携の構成。OpenCTI 本体にMCP機能はなく、XTM One が提供する。

XTM One は **MCP (Model Context Protocol) サーバー** として動作する。

MCP とは、AIアシスタントが外部のツールやデータにアクセスするための標準規格である。これに対応したAIクライアント（ChatGPT、Claude など）から、OpenCTI のデータを直接操作できるようになる。

確認した事実

- OpenCTI 本体に MCP サーバー機能は**ない**。XTM One が提供する
- エンドポイントは `POST /mcp/opencti`（Streamable HTTP、JSON-RPC 2.0）
- **Community Edition の機能**であり、EE ライセンスもLLMも介在しない
- 公開されるツールは28種類

公開される28ツールの内訳は以下のとおりである。

```
検索・読み取り (11) : search / get_entity / get_relationship /
                        list_entities / list_observables /
                        list_relationships / container_full /
                        entity_stats / top_related / entity_history /
                        validate_nlp_filter
作成 (6)              : entity / relationship / observable /
                        indicator / container / note
更新 (2)              : field / relationship_field
削除 (2)              : entity / relationship
ラベル・マーキング (4)
Container 操作 (2)
観測値の昇格 (1)
```


ユーザー管理、ロール、プレイブック、ダッシュボード、コネクタ、設定といった**プラットフォーム管理系のツールは意図的に除外**されている。許可リスト方式であり、新しいツールは明示的に許可するまで公開されない。

実機での接続確認

ChatGPT Desktop アプリから接続し、28ツールすべてが認識されることを確認した。設定はカスタムMCPとして「ストリーミング可能な HTTP」を選択し、URLと Bearer トークンを指定するだけである。

ChatGPT Desktop は MCP クライアントを**ローカルで実行する**ため、`localhost` のURLで接続できる。OpenCTI をインターネットに公開する必要はない。

何に使えるか

CTI プラットフォームを開くことなく、普段使っているAIアシスタントの対話の中で脅威情報を参照できる。「この攻撃グループについて社内のデータベースに何がある?」と尋ねれば、AIが検索して答える。

注意すべき点

公開ツールには削除系が含まれ、しかも下書きを経由せず**即座に本番データへ反映される**。AIクライアントに接続する場合は、削除権限を持たない専用ユーザーを用意すべきである。

4. AI以外の Enterprise Edition 機能

AIが主題であるが、EEの価値を理解するには他の機能も押さえる必要がある。特に自動化系はAI機能と組み合わせで効果を発揮する。

4.1 プレイブック — ノーコードの自動処理

何をするものか

取り込んだデータに対して、あらかじめ定義した処理を自動実行する仕組みである。プログラミング不要で、画面上でブロックをつないで組み立てる。

処理の単位は STIX Bundle であり、以下のような部品を組み合わせる。

- **フィルタ** — 条件に合うデータだけを通す
- **加工** — 属性を書き換える
- **エンリッチ** — ラベルやマーキングを付与する、外部サービスに問い合わせる
- **分岐** — 条件によって処理を分ける
- **保存** — プラットフォームに書き戻す

何に使えるか

公式ドキュメントが挙げる用途は以下である。

- レポートからインシデント対応ケースを自動生成する
- 情報源の信頼度に応じて Indicator のスコアを自動調整する
- 脆弱性のトリアージ（優先度付け）を自動化する
- データフィードの品質チェックを自動化する

SOC の運用に引き寄せると、たとえば外部フィードから流入した Indicator のうち、自社の EDR やプロキシで既にブロック済みのものを除外し、未対応のものだけを検知エンジニアのキューに回す、という振り分けが組める。「取り込んだデータを人手でラベル付けしている」という状況があるなら、その大半はプレイブックで置き換えられる。

4.2 PIR — 重要な脅威だけを浮かび上がらせる

何をするものか

PIR（Priority Intelligence Requirements、優先情報要求）は、軍事・諜報分野に由来する概念である。「意思決定のために本当に必要な情報は何か」を事前に定義しておく考え方を指す。

CTI の現場では、日々膨大な脅威情報が流入する。そのすべてが自組織に関係するわけではない。PIR は、**自組織にとって重要な条件をあらかじめ定義し、合致する脅威を自動的に選り分ける**機能である。

仕組み

1. 条件を定義する（例: 「自社が利用する VPN 製品の脆弱性を悪用する」「信頼度60%以上」）
2. 流入してくるデータを監視する
3. 条件に合致する Entity に **PIRスコア**（条件の何%を満たすか）を付与する
4. スコアは関係の増減に応じて動的に更新される

たとえば「自社の業種を狙う」「自社が使う製品を悪用する」の2条件を定義した場合、両方に該当するマルウェアは100%、片方だけなら50%となる。

何に使えるか

SOC が扱う脅威情報を、自社の資産構成に合わせて絞り込める。自社が特定の VPN 製品や OS を使っているなら、それを悪用する攻撃にだけスコアが付く。日々のアラートトリアージにおける「これは自社に関係するのか」という判断を、事前に定義した基準に落とし込める点に価値がある。情報過多への対処として設計された機能である。

4.3 ドラフトワークスペース — 本番データを壊さない作業場

何をするものか

本番の知識ベースに影響を与えずに、データの作成・変更・削除を試せる隔離環境である。変更内容は Review タブで差分として確認でき、承認して初めて本番に反映される。

なお、ドラフト機能そのものは CE でも利用できる。EE で追加されるのは「**ドラフトモード権限制御**」、すなわち特定のユーザーに対して**本番データの直接編集を禁止し、必ずドラフト経由にする**という強制である。

何に使えるか

複数人でCTIを運用する組織において、経験の浅いメンバーの作業を必ずレビュー経由にする、といった品質統制が可能になる。

4.4 全文ファイル索引 — PDFの中身を検索する

何をするものか

アップロードされたファイルからテキストを抽出し、検索対象に含める機能である。対応形式は PDF、テキスト、CSV、HTML、Excel（.xls / .xlsx）である。新規アップロードは5分ごとに索引化される。

これがないと、ファイルは「添付されたもの」でしかなく、中身を検索できない。

技術的な前提

Elasticsearch 8.4 以上、または ingest-attachment プラグインを導入した環境が必要である。既定の最大ファイルサイズは5MBで、形式ごとに索引化の有効・無効を切り替えられる。

AI機能との関係

重要な点として、**AIによる文書処理機能（`aiConvertFilesToStix` など）は、この索引から抽出済みテキストを読む**。したがって全文索引が無効だと、AI機能も文書を読めない。AI機能を使うなら必須の設定である。

4.5 Activity Monitoring — 監査ログ

何をするものか

「誰が、いつ、どこで、何をしたか」を記録する。記録内容は3階層に分かれる。

階層	内容
Basic Knowledge	STIXデータの作成・更新・削除。Entity 履歴から参照
Extended Knowledge	指定したユーザー・グループの操作追跡（性能を考慮し任意設定）
Audit Knowledge	認証成否、ロール・グループ・ユーザー管理、コネクタ設定変更、ポリシー変更など。常時記録

ログは機械可読な JSON 形式で、認証情報・カテゴリ・タイムスタンプ・リソース種別といった標準フィールドを持つ。

何に使えるか

規制対応の監査証跡、不正アクセスの調査、データガバナンスの確認が主な用途である。

4.6 組織セグリゲーションと Authorized Members

OpenCTI のアクセス制御は、標準では **マーキング定義**（TLPなど機密区分ラベル）とグループ権限の組み合わせで行う。これは CE でも利用できる。

EE が追加するのは以下の2つである。

組織セグリゲーション — ユーザーが所属する組織単位でデータを見せ分ける。複数組織が同一プラットフォームを共有する構成（業界ISACなど）で必要になる。

Authorized Members — 個別のデータに対して、閲覧・編集・管理の権限を人単位で指定する。特定の機密案件を関係者だけに限定する用途である。

補足として **TLP**（Traffic Light Protocol）は、情報の取り扱い範囲を色で示す国際的な慣行である。RED（指定された個人のみ）、AMBER（組織内）、GREEN（コミュニティ内）、CLEAR（制限なし）の4段階が基本となる。

4.7 Fintel テンプレート — ブランド付きレポート出力

Fintel は Finished Intelligence（完成した情報成果物）の略である。分析結果を、受け手に配布できる体裁の文書に仕上げたものを指す。

この機能は、レポートを **自社のロゴ・配色を適用したPDFとして出力する**テンプレートを定義する。設定は Settings > Customization > Fintel designs から行い、ロゴ（PNG/JPG/SVG）、グラデーション色、文字色を指定する。実データを使ったプレビューが表示される。

何に使えるか

CISO 向けの月次セキュリティ報告、グループ会社の SOC への共有資料、業界 ISAC（情報共有分析組織）への提供文書など、チームの外に出す成果物の体裁を統一する。

4.8 配信リストとメールテンプレート

配信リストは、完成した文書を指定した宛先グループへメール配信する機能である。**メールテンプレート**は、通知メールの文面を定型化する機能である。

Fintel テンプレートと組み合わせることで、「レポートを作成 → ブランド付きPDFに変換 → 関係者へ配信」という一連の流れがプラットフォーム内で完結する。

4.9 SSO（シングルサインオン）

OpenID Connect、LDAP、SAML、クライアント証明書、HTTPヘッダー認証による認証統合である。7系から EE 機能となった。

何に使えるか

既存の社内認証基盤（Active Directory、Okta など）と統合し、アカウント管理を一元化する。組織で運用する上では実質的に必須となる。

5. 何に使えるか — ユースケース別の整理



図4 取り込みから活用までの流れ。EE機能がどの工程を担うかを示す。

機能単位ではなく、業務の流れに沿って整理する。

5.1 脅威情報の取り込みを効率化する

課題: 脅威レポートのPDFを SOC/CTI チームが読んで手作業でデータ化しており、1本あたり数時間かかる。

該当機能: 全文ファイル索引 + AI文書→STIX変換 + ドラフトワークスペース + ブレイブック

流れ:

1. PDFをアップロードすると全文索引に登録される
2. AIが文書を読み、Entity と関係を抽出する
3. 結果はドラフトに入り、アナリストが差分を確認する
4. 承認すると本番の知識ベースに反映される
5. ブレイブックが自動でラベル付けやスコア調整を行う

期待効果: 実測ではAIが13件の関係を抽出した。関係の抽出はパターンマッチでは0件であり、従来は完全に人手だった部分である。ただしAIの出力は完璧ではなく、レビュー工程は依然として必要である。

5.2 重要な脅威を見逃さない

課題: 流入する脅威情報が多すぎて、SOC が自社に関係するものを選び分けきれない。

該当機能: PIR + 通知

流れ: 自社の業種、拠点地域、利用製品、OS構成といった条件を PIR として定義しておく、合致する脅威にスコアが付き、優先度順に並ぶ。新たに該当する脅威が現れた時点で通知を受け取れる。

5.3 報告書の作成負荷を下げる

課題: 同じインシデント分析を、CISO 向けの報告書と SOC 内の引き継ぎ資料に書き分けており、時間を取られる。

該当機能: AIレポート生成 + Ask AI (トーン変更) + Fintel テンプレート + 配信リスト

流れ: 知識グラフからAIが報告文を生成し、Strategic / Tactical / Operational の3トーンに書き分け、ブランド付きPDFとして出力し、配信リストで関係者に届ける。

5.4 アナリスト以外にもデータを使えるようにする

課題: CTIプラットフォームが CTI 専任アナリストの専用ツールになっており、SOC の当番アナリストやインシデント対応担当が使えない。

該当機能: NLQ + MCP連携

流れ: NLQ により普通の文章で検索できる。さらに MCP 経由で ChatGPT などに接続すれば、慣れたAIアシスタントの対話の中でデータを参照できる。アラート対応の最中に、調査対象の IP やドメインについて社内の蓄積を即座に引ける状態をつくれる。

5.5 組織として統制の効いた運用にする

課題: 誰が何を変更したか追跡できない。進行中のインシデント情報へのアクセス制御が甘い。

該当機能: Activity Monitoring + 組織セグリゲーション + Authorized Members + ドラフトモード権限制御 + SSO

6. ライセンスと導入

6.1 ライセンスの仕組み

実装を確認したところ、EEライセンスは **X.509証明書** の形式で提供される。OpenCTI に組み込まれたCA証明書で署名を検証し、証明書の拡張フィールドからライセンス種別・発行者・製品名を読み取る仕組みである。

確認できたライセンス種別は5つである。

種別	内容
<code>standard</code>	通常の商用ライセンス
<code>trial</code>	試用ライセンス
<code>nfr</code>	Not For Resale（開発・研究・非営利団体向け）
<code>lts</code>	長期サポート版向け
<code>ci</code>	CI環境向け

ライセンスはプラットフォームの内部IDに紐づくか、`global` 指定で任意のインスタンスに適用できる。

6.2 入手方法

公式ドキュメントおよび Filigran のサイトによれば、以下の経路がある。

- **無償トライアル**: 30日間、全機能に制限なくアクセスできる
- **無償ライセンス**: 開発・研究用途、および非政府系の慈善団体向けに提供される
- **SaaS契約**: Filigran のクラウド版には自動的に含まれる
- **オンプレミス**: Filigran との企業契約が必要である

具体的な価格体系（ユーザー単位か、インスタンス単位かなど）については、公開情報からは確認できなかった。

6.3 トライアル期限切れ時の挙動

公式ドキュメントには期限切れ後の挙動の明記がない。実装コードには `license_expired` の判定と、トライアル・CI以外のライセンスについて期限3か月前から警告を出す処理が存在することを確認した。

検証環境では、期限が切れると EE 機能が利用できなくなる想定で運用した（実際に期限切れを経験する前にトライアルが更新されたため、切れた状態の挙動は未確認である）。

6.4 AI機能を使う場合の追加要件

EE ライセンスとは別に、以下が必要である。

LLMの用意: OpenCTI 自体はモデルを内蔵しない。以下のいずれかを用意する。

- Filigran のホスト型AIサービス
- OpenAI / MistralAI / Azure OpenAI の商用API
- OpenAI互換のローカル推論サーバー（Ollama、vLLM など）

リソース: XTM One を含む構成では、検証環境で約1.6GB の追加メモリを消費した。またコンテナは amd64 向けに提供されるため、Apple Silicon 上ではエミュレーションのオーバーヘッドが生じる。

全文ファイル索引の有効化: AIの文書処理機能は索引済みテキストを読むため、必須である。

7. 注意点と限界

事実に基づき、導入検討時に留意すべき点を挙げる。

7.1 データが外部に出る経路

AI機能を使う以上、処理対象のデータは推論を行う場所へ送られる。検証環境で確認した外部送信経路は以下である。

経路	送信先	制御方法
LLM推論	設定したプロバイダ	<code>AI__ENDPOINT</code> で変更可
XTM Oneの2エージェント	Filigran のクラウド	<code>FILIGRAN_AI_BASE_URL_*</code> で変更可
利用統計テレメトリ	Filigran の収集基盤	起動時の接続確認に失敗すると自動的に無効化される

特に注意すべきは XTM One の文書→STIX変換とTTP抽出エージェントである。 既定のまま使うと、投入した文書の本文が Filigran のサーバーに送信される。認証も不要な設計である。機密文書を扱う場合は、必ず送信先を確認・変更すべきである。

なお「ローカルのOllamaを使っているから安全」という理解には注意が必要である。モデル名に `-cloud` が付くものはOllamaのクラウドで推論が実行される。検証環境で使用した `gpt-oss:120b-cloud` は約1170億パラメータであり、ローカルには重みが存在しなかった。

7.2 UIとAPIの機能差

実機検証で確認した重要な事実として、**API経由で動作する機能が、UI上では利用できない場合がある。**

たとえば `aiConvertFilesToStix`（文書→STIX変換）は API では動作するが、フロントエンドのバンドルを調査した結果、このミューテーション名自体が含まれておらず、UI からは呼び出せなかった。また NLQ は API では XTM One なしで動作するが、検索バーのボタンは XTM One 必須のゲートが掛かっていた。

導入検討にあたっては、カタログ上の機能名だけでなく、実際にUIから使えるかを確認することを推奨する。

7.3 ドキュメントの整備状況

AI関連の中核ページ（`usage/copilot/`、`usage/insights/`）は執筆時点で "Under construction" であり、内容が公開されていない。XTM One は2026年6月発表と新しく、公開情報が製品ページとプレスリリース中心である。

情報が必要な場合は、実機での検証か、Filigran への直接問い合わせが必要になる。

7.4 AIの出力品質

実測した文書→STIX変換では、AI側の出力に**6件の孤立した Indicator**（他の Entity と関係を持たないもの）が含まれていた。また抽出されたオブジェクト数はパターンマッチの5分の1以下である。

AIは「意味を理解した関係抽出」に強みがある一方、**網羅性ではパターンマッチに劣る**。どちらか一方に置き換えるのではなく、併用したうえで人間がレビューする前提で設計すべきである。

7.5 リソース要件

検証環境（16GBメモリのMac）での実測値である。

構成	コンテナ数	メモリ使用量
コアのみ	6	約4.4GB
AI拡張込み	11	約6.1GB

Elasticsearch が単独で3.3GBを占める。本番運用では、これに取り込むデータ量に応じた増加を見込む必要がある。

8. まとめ

8.1 EEで何ができるようになるか

一言で言えば、「**個人が使う知識データベース**」を「**組織で回る情報生産システム**」に変えられる。

- **入口:** AIが文書から知識を抽出し、人間の入力作業を減らす
- **選別:** PIRが自組織に関係する脅威だけを浮かび上がらせる
- **加工:** プレイブックが定型処理を自動化する
- **出口:** AIが報告文を生成し、ブランド付きPDFとして配信する
- **統制:** 監査ログとアクセス制御が組織運用を支える

8.2 AI機能の現在地

実用段階にあるもの

- 文章支援（要約、トーン変更） — 効果が明確で、失敗のリスクも低い
- NLQ — 日本語が通り、応答は数秒。利用者の裾野を広げる
- 文書からの関係抽出 — 従来は完全に人手だった領域を代替する

判断が要るもの

- 文書→STIX変換 — 関係抽出という明確な価値がある一方、網羅性に課題があり、レビュー工程を前提とする設計が必要である
- XTM Oneのエージェント — 能力は高いが、外部送信の設定確認が必須である

未確認のもの

- AI Insights の詳細な挙動 — 公式ドキュメントが未整備であり、実機検証も未了である

8.3 検討にあたっての提言

まず**30日間の無償トライアルで実データを使って試すこと**を推奨する。EEの価値は機能一覧からは判断しにくく、自組織のデータと運用に当てはめて初めて見えるためである。

その際、以下の3点を確認するとよい。

1. 手元の脅威レポートPDFで、AIがどこまで関係を抽出できるか
2. 自組織の関心事をPIRとして表現できるか
3. AI機能を使う際、データがどこへ送信されるかが許容できるか

付録A. 用語集

用語	意味
CTI	サイバー脅威インテリジェンス。攻撃者に関する知識の収集・活用
SOC	セキュリティ監視センター。アラートの監視と初動対応を行う組織
CISO	最高情報セキュリティ責任者
EDR	端末上の挙動を監視し、不審な動作を検知・遮断する仕組み
ISAC	情報共有分析組織。業界単位で脅威情報を共有する枠組み
トリアージ	大量のアラートや脆弱性に優先順位を付けて捌く作業
脅威ハンティング	アラートを待たず、仮説を立てて能動的に侵害の痕跡を探す活動
STIX	脅威情報を記述する国際標準フォーマット
TAXII	STIXデータを組織間でやりとりするための通信規約
TLP	情報の取扱範囲を色で示す国際的慣行
IOC	侵害の痕跡。IPアドレスやハッシュ値など
TTP	戦術・技術・手順。攻撃者の行動パターン
MITRE ATT&CK	攻撃手法を体系化した知識ベース
Entity	攻撃グループやマルウェアなど、STIXにおける「モノ」
Bundle	複数の STIX オブジェクトをまとめて受け渡すための入れ物
Observable	観測された値そのもの。IPアドレスやファイル名
Indicator	攻撃の兆候を判定するための検知ルール
Container (OpenCTI)	レポートやケースなど、複数の Entity をまとめる OpenCTI 側の入れ物
LLM	大規模言語モデル。文章を生成するAI
NLQ	自然言語クエリ。普通の文章での検索
PIR	優先情報要求。重視すべき情報を事前定義する枠組み
Fintel	完成した情報成果物。配布可能な体裁の分析結果
MCP	AIが外部ツールに接続するための標準規格
エージェント型AI	目標を与えると自ら手順を考えて実行するAI

用語	意味
RBAC	役割に基づくアクセス制御
SSO	シングルサインオン。認証基盤の統合

付録B. 検証環境の詳細

ホスト : Apple Silicon Mac / メモリ 16GB
Docker Desktop 割当 10.4GB

OpenCTI : 7.260710.0 (arm64ネイティブ)

XTM One : 1.260711.0 (amd64エミュレーション)

検索エンジン : Elasticsearch 8.19.16

LLM : Ollama Cloud / gpt-oss:120b-cloud (約1170億パラメータ)
埋め込み用 nomic-embed-text (ローカル)

ライセンス : trial (有効期限 2026年9月16日)

投入データ

Entity : 6,427

Observable : 691

関係 : 26,439

レポート : 24

出典 : MITRE ATT&CK 全体 + 公開脅威レポート

付録C. 参考資料

- OpenCTI 公式ドキュメント — <https://docs.opencti.io/latest/>
- Enterprise Edition 機能一覧 — <https://docs.opencti.io/latest/administration/enterprise/>
- Ask AI（文章支援・NLQ） — <https://docs.opencti.io/latest/usage/refine-content/>
- プレイブック — <https://docs.opencti.io/latest/usage/playbook-automation/>
- PIR — <https://docs.opencti.io/latest/usage/pir/>
- 全文ファイル索引 — <https://docs.opencti.io/latest/administration/file-indexing/>
- 監査ログ — <https://docs.opencti.io/latest/administration/audit/overview/>
- ドラフトワークスペース — <https://docs.opencti.io/latest/usage/draftWorkspaces/>
- Fintel デザイン — <https://docs.opencti.io/latest/administration/fintel-designs/>
- データセグリゲーション — <https://docs.opencti.io/latest/administration/segregation/>
- XTM One 製品ページ — <https://filigran.io/platform/xtm-one/>
- EE 無償トライアル — <https://filigran.io/opencti-enterprise-edition-free-trial>

本レポートは 2026年8月27日時点の公開情報および実機検証に基づく。OpenCTI は活発に開発が進むプロダクトであり、記載内容は将来のバージョンで変わりうる。